

NovaTech Solutions Pvt. Ltd.

Information Security Policy (ISO 27001 Aligned)

Document ID: COMP-SEC-001

Version: 2.0

Effective Date: January 2026

Prepared By: Information Security Office

Classification: Internal Use Only

Document Control

Field	Value
Document	Information Security Policy
Department	Information Security
Version	2.0
Owner	Chief Information Security Officer (CISO)
Review Cycle	Annual
Last Updated	January 2026

Table of Contents

1. Introduction
2. Information Security Policy Statement
3. Purpose
4. Scope
5. Information Security Objectives
6. Roles and Responsibilities
7. Information Classification
8. Asset Management

1. Introduction

NovaTech Solutions Pvt. Ltd. is committed to protecting information assets against unauthorized access, disclosure, modification, destruction, and disruption.

This Information Security Policy establishes the principles and governance framework for protecting organizational information, customer data, technology resources, and business operations.

The policy supports secure business operations and promotes a culture of security awareness across the organization.

2. Information Security Policy Statement

Information security is a shared responsibility across all employees, contractors, consultants, vendors, and third-party service providers.

NovaTech is committed to:

- Protecting the confidentiality of information.
- Maintaining information integrity.
- Ensuring service availability.
- Managing information security risks.
- Supporting regulatory and contractual compliance.
- Continuously improving security controls.

Security requirements apply to all business operations involving company information.

3. Purpose

The objectives of this policy are to:

- Protect organizational information assets.
 - Reduce cybersecurity risks.
 - Define security responsibilities.
 - Establish consistent security practices.
 - Protect customer information.
 - Support secure software development.
 - Maintain business continuity.
 - Enable compliance with applicable legal and contractual requirements.
-

4. Scope

This policy applies to:

- Employees

- Contractors
- Consultants
- Temporary staff
- Interns
- Third-party service providers
- Business partners with authorized system access

The policy covers:

- Information assets
- Information systems
- Cloud services
- Networks
- End-user devices
- Applications
- Databases
- Physical facilities
- Digital communication platforms

All personnel with access to NovaTech information are expected to comply with this policy.

5. Information Security Objectives

NovaTech maintains the following information security objectives.

Confidentiality

Information should only be accessible to authorized individuals with a legitimate business need.

Examples include:

- Customer information
 - Employee records
 - Financial data
 - Product roadmaps
 - Source code
-

Integrity

Information should remain accurate, complete, and protected from unauthorized modification.

Integrity controls include:

- Access restrictions
 - Version control
 - Audit logging
 - Change management
 - Data validation
-

Availability

Business systems should remain available to authorized users when required.

Availability is supported through:

- Redundant infrastructure
 - System monitoring
 - Backup procedures
 - Disaster recovery planning
 - Incident response
-

Risk Management

Security risks should be identified, assessed, and managed using approved organizational processes.

Risk treatment activities include:

- Risk reduction
- Risk avoidance
- Risk transfer
- Risk acceptance

Risk decisions should be documented and reviewed periodically.

6. Roles and Responsibilities

Information security responsibilities are shared throughout the organization.

Chief Information Security Officer (CISO)

The CISO is responsible for:

- Information Security governance.
- Security strategy.
- Policy approval.
- Security risk management.
- Compliance oversight.
- Executive reporting.

Information Security Team

Responsible for:

- Security monitoring.
- Vulnerability management.
- Security awareness.
- Incident response.
- Security assessments.
- Policy maintenance.

Information Technology Team

Responsible for:

- Infrastructure security.
- Identity management.
- System patching.
- Backup operations.
- Endpoint protection.
- Network security.

Engineering Teams

Responsible for:

- Secure software development.
 - Security testing.
 - Dependency management.
 - Code reviews.
 - Secure deployment practices.
-

Department Managers

Managers should:

- Ensure policy compliance.
 - Approve appropriate access.
 - Support employee training.
 - Report security concerns.
-

Employees

Every employee is responsible for:

- Protecting company information.
- Following security procedures.
- Using approved systems.
- Reporting suspected security incidents.
- Completing mandatory security awareness training.

Failure to comply with security policies may result in disciplinary action.

7. Information Classification

Information should be classified according to its sensitivity and business value.

Public

Information approved for unrestricted public distribution.

Examples:

- Marketing materials
- Public website content

- Press releases
-

Internal

Information intended for internal business use.

Examples:

- Internal procedures
 - Department documentation
 - Meeting notes
-

Confidential

Information requiring controlled access.

Examples:

- Customer records
 - Financial reports
 - Product documentation
 - Employee information
-

Restricted

Highly sensitive information requiring the highest level of protection.

Examples:

- Encryption keys
- Authentication secrets
- Security credentials
- Source code repositories
- Acquisition documents

Access to Restricted information should be granted only on a need-to-know basis.

Information Handling

Personnel should:

- Label information appropriately.

- Store information securely.
- Share information only with authorized recipients.
- Dispose of information using approved methods.

Information classification should be reviewed whenever business requirements change.

8. Asset Management

Information assets should be identified, documented, and protected throughout their lifecycle.

Asset Categories

Examples include:

- Laptops
 - Servers
 - Databases
 - Applications
 - Mobile devices
 - Cloud resources
 - Software licenses
 - Source code repositories
 - Documentation
-

Asset Ownership

Each information asset should have an assigned owner responsible for:

- Classification
- Appropriate use
- Access approval
- Security requirements
- Lifecycle management

Ownership responsibilities remain active throughout the asset lifecycle.

Acceptable Use

Company assets should be used only for authorized business purposes.

Users should not:

- Install unauthorized software.
- Disable security controls.
- Share credentials.
- Store confidential information on unapproved devices.
- Use company resources for unlawful activities.

Asset Inventory

The Information Technology Department maintains an inventory including:

- Asset identifier
- Owner
- Location
- Classification
- Status
- Lifecycle stage

Asset inventories should be reviewed periodically for accuracy.

Asset Disposal

Before disposal or reassignment:

- Sensitive information should be securely removed.
- Storage devices should be sanitized.
- Asset records should be updated.
- Disposal activities should be documented.

Approved disposal procedures reduce the risk of unauthorized data disclosure.

Revision History

Version	Date	Description
1.0	January 2024	Initial Information Security Policy
1.5	July 2025	Added Information Classification and Asset Management

Version	Date	Description
2.0	January 2026	Updated Security Objectives, Governance, and Roles

9. Access Control

Access to information systems shall be granted according to the principle of **least privilege** and **business need**.

Users should receive only the permissions required to perform their assigned responsibilities.

Access Provisioning

Access requests should:

- Be formally approved.
- Be linked to a business requirement.
- Follow role-based access assignments.
- Be recorded within the Identity Management System.

Temporary access should have a defined expiration date.

Access Review

Managers should periodically review user access to ensure permissions remain appropriate.

Access reviews should verify:

- Active users
- Assigned roles
- Privileged accounts
- Dormant accounts
- Temporary access

Unnecessary access should be removed promptly.

Account Management

The Information Technology team should:

- Create user accounts.

- Disable inactive accounts.
- Remove access for separated employees.
- Monitor privileged accounts.
- Maintain audit records.

Shared user accounts should be avoided unless explicitly approved.

10. Password Policy

Passwords remain an important security control and must be protected appropriately.

Password Requirements

Passwords should:

- Be unique.
- Contain sufficient complexity.
- Not be easily guessed.
- Not contain personal information.
- Be changed immediately if compromise is suspected.

Passwords must never be shared.

Password Storage

Passwords shall:

- Never be stored in plain text.
 - Be protected using approved authentication mechanisms.
 - Be transmitted only through secure communication channels.
-

Password Managers

Approved password management software may be used for storing business credentials.

Employees should not maintain passwords in:

- Text documents
- Email messages
- Sticky notes

- Unencrypted spreadsheets
-

11. Multi-Factor Authentication (MFA)

Multi-Factor Authentication provides an additional layer of protection for user accounts.

MFA Requirements

MFA should be enabled for:

- Administrative accounts
- Remote access
- Cloud services
- VPN access
- Privileged systems

Additional systems may require MFA based on risk assessments.

Authentication Factors

Examples include:

- Password
- Authentication application
- Hardware security token
- Biometric verification

The use of multiple independent authentication factors improves account security.

12. Cryptography

Cryptographic controls protect sensitive information during storage and transmission.

Encryption

Sensitive information should be encrypted:

- During transmission across public networks.
- When stored on approved systems where required by policy or regulation.

Encryption methods should be selected according to organizational standards and current industry practices.

Encryption Key Management

Encryption keys should:

- Be generated securely.
- Be stored separately from encrypted data where practical.
- Be accessible only to authorized personnel.
- Be rotated when required.
- Be retired securely when no longer needed.

Unauthorized disclosure of encryption keys should be treated as a security incident.

13. Physical Security

Physical security protects facilities, equipment, and information assets from unauthorized access.

Facility Access

Access to secure areas should be restricted through approved controls.

Examples include:

- Access cards
- Security personnel
- Visitor registration
- Electronic access logs

Visitors should be escorted within restricted areas unless otherwise authorized.

Workstation Security

Employees should:

- Lock workstations when unattended.
- Protect confidential information from unauthorized viewing.
- Secure portable devices.
- Follow clean desk practices.

Sensitive documents should not remain unattended.

14. Network Security

Networks should be designed and managed to reduce security risks.

Network Protection

Security controls may include:

- Firewalls
- Network segmentation
- Intrusion detection
- Intrusion prevention
- Secure remote access
- Traffic monitoring

Network configurations should follow approved standards.

Wireless Networks

Wireless networks should:

- Require authentication.
- Use approved encryption.
- Restrict unauthorized devices.
- Be monitored regularly.

Guest networks should be isolated from production systems.

15. Endpoint Security

Endpoints represent a common target for cyber threats and require appropriate protection.

Endpoint Controls

Company-managed devices should include:

- Endpoint protection software
- Operating system updates
- Device encryption (where applicable)
- Screen locking

- Approved software only

Security controls should not be disabled without authorization.

Patch Management

Systems should receive security updates within organizationally approved maintenance schedules.

Critical vulnerabilities should be addressed with priority.

16. Secure Software Development

Engineering teams should integrate security throughout the software development lifecycle.

Secure Development Practices

Developers should:

- Follow secure coding guidelines.
- Review code before deployment.
- Validate user input.
- Protect sensitive information.
- Minimize security vulnerabilities.

Security should be considered during design, implementation, testing, and deployment.

Security Testing

Applications should undergo appropriate security testing before production release.

Testing may include:

- Static code analysis
- Dependency analysis
- Vulnerability assessment
- Penetration testing
- Manual security review

Findings should be addressed according to risk.

17. Third-Party Security

Third-party providers may access organizational systems or process organizational information.

Appropriate security controls should be applied before granting access.

Vendor Assessment

Security evaluations may include:

- Information security practices
- Compliance certifications
- Risk assessment
- Data protection capabilities
- Incident response procedures

The level of review should reflect the risk associated with the vendor relationship.

Third-Party Access

External users should:

- Receive only approved access.
- Follow NovaTech security requirements.
- Protect confidential information.
- Report security incidents promptly.

Access should be reviewed periodically and removed when no longer required.

18. Human Resource Security

Security responsibilities begin before employment and continue throughout the employment lifecycle.

Pre-Employment

Where appropriate, employment processes may include:

- Identity verification
- Reference checks
- Background verification
- Confidentiality agreements

Verification activities should comply with applicable laws and organizational policies.

During Employment

Employees should:

- Complete mandatory security awareness training.
- Protect organizational information.
- Follow approved security procedures.
- Report suspected security incidents.
- Comply with this policy.

Managers should reinforce security responsibilities through regular communication.

Separation Process

When employment or contractual relationships end:

- System access should be removed.
- Company equipment should be returned.
- Confidential information should remain protected.
- Security obligations continue after separation where required by agreement.

Exit procedures should be completed promptly.

Security Awareness

NovaTech promotes a security-aware culture through ongoing education.

Training topics include:

- Phishing awareness
- Password security
- Social engineering
- Data protection
- Secure remote work
- Incident reporting
- Acceptable use
- Regulatory responsibilities

Employees should complete mandatory security training according to organizational requirements.

19. Security Incident Management

All suspected or confirmed information security incidents should be reported immediately.

Prompt reporting enables timely investigation, containment, and recovery while minimizing business impact.

Incident Reporting

Employees should report incidents involving:

- Unauthorized system access
- Malware infections
- Lost or stolen devices
- Suspicious emails
- Data leakage
- Credential compromise
- Network intrusions
- Unauthorized software installation

Reports should be submitted through the approved Incident Management process.

Incident Response

Security incidents should follow a structured response process that includes:

- Detection
- Assessment
- Containment
- Investigation
- Eradication
- Recovery
- Post-incident review

The Information Security Team coordinates technical investigations with affected business units.

20. Business Continuity

NovaTech maintains Business Continuity and Disaster Recovery capabilities to support critical business operations.

Continuity Objectives

Business continuity planning aims to:

- Protect critical business services.
 - Minimize operational disruption.
 - Support customer commitments.
 - Restore essential systems within approved recovery objectives.
-

Recovery Planning

Recovery procedures should address:

- Infrastructure restoration
- Application recovery
- Database recovery
- Network restoration
- Identity services
- Customer communications

Recovery plans should be reviewed and tested periodically.

21. Backup & Recovery

Backups protect organizational information against accidental loss, corruption, or system failure.

Backup Requirements

Critical systems should have documented backup procedures covering:

- Databases
- Application configurations
- Virtual machines

- Cloud resources
- Business documentation

Backup schedules should align with business requirements.

Recovery Testing

Recovery procedures should be tested periodically to verify that:

- Backup media is usable.
- Recovery documentation is accurate.
- Recovery objectives can be achieved.

Testing results should be documented.

22. Logging & Monitoring

Security monitoring supports early detection of suspicious activity.

Logging

Appropriate systems should generate logs for:

- User authentication
- Administrative actions
- System changes
- Security events
- Application activity
- Network access

Logs should be protected from unauthorized modification.

Monitoring

Security monitoring may include:

- Intrusion detection
- Endpoint monitoring
- Network monitoring
- Security alerts

- Vulnerability monitoring
- Threat intelligence

Security events should be investigated according to their severity.

23. Compliance Requirements

NovaTech is committed to complying with applicable legal, regulatory, contractual, and organizational requirements.

Compliance Areas

Examples include:

- Data protection laws
- Customer contractual obligations
- Employment legislation
- Financial regulations
- Internal policies
- Information security requirements

Compliance responsibilities apply across all departments.

Internal Audits

Periodic audits evaluate:

- Policy compliance
- Security controls
- Documentation quality
- Access management
- Risk management
- Incident management

Audit findings should be documented and tracked until resolution.

24. Policy Exceptions

Policy exceptions should be granted only when a legitimate business requirement exists.

Exception Requests

Requests should include:

- Business justification
- Affected systems
- Risk assessment
- Proposed compensating controls
- Requested duration

Exceptions require documented approval by authorized personnel.

Exception Review

Approved exceptions should be reviewed periodically to determine whether they remain necessary.

Expired exceptions should be removed or renewed through the approval process.

25. Security Training & Awareness

Security awareness is essential for maintaining an effective Information Security Management System.

Mandatory Training

Personnel should complete training covering:

- Information Security Policy
- Password security
- Multi-Factor Authentication
- Phishing awareness
- Data classification
- Incident reporting
- Secure remote work
- Acceptable use

Completion records should be maintained by Human Resources and the Information Security Team.

Awareness Activities

Additional awareness initiatives may include:

- Security newsletters
- Simulated phishing campaigns
- Awareness workshops
- Team presentations
- Security reminders

These activities reinforce secure behavior throughout the organization.

26. Policy Review & Maintenance

This policy should be reviewed regularly to ensure continued relevance and effectiveness.

Review Frequency

The Information Security Policy should be reviewed:

- Annually
- After significant business changes
- Following major security incidents
- After regulatory changes
- Following significant technology changes

Updates should be approved before publication.

Document Control

Policy revisions should record:

- Version number
- Approval date
- Summary of changes
- Policy owner
- Review schedule

Previous versions should be retained according to document retention requirements.

27. Continuous Improvement

NovaTech continually improves its Information Security Management System.

Improvement Activities

Continuous improvement may include:

- Reviewing security incidents
- Updating security controls
- Improving monitoring capabilities
- Enhancing employee training
- Reviewing risk assessments
- Updating operational procedures
- Conducting security exercises

Lessons learned should be incorporated into future security initiatives.

28. Definitions

Term	Definition
Asset	Any item that has value to the organization
Confidentiality	Protection against unauthorized disclosure
Integrity	Protection against unauthorized modification
Availability	Information accessible when required
Information Asset	Information or systems supporting business operations
Least Privilege	Granting only the minimum access necessary
MFA	Multi-Factor Authentication
Risk	Potential impact of uncertainty on business objectives
Security Incident	Event affecting the confidentiality, integrity, or availability of information

29. Frequently Asked Questions

Q1. Who is responsible for information security?

Information security is a shared responsibility across all employees, contractors, managers, and the Information Security Team.

Q2. What should I do if I receive a suspicious email?

Do not interact with the message. Report it immediately using the approved incident reporting process.

Q3. Why is Multi-Factor Authentication required?

MFA provides an additional layer of protection against unauthorized account access.

Q4. Can confidential information be stored on personal devices?

Only where explicitly authorized and protected according to organizational security requirements.

Q5. How often is this policy reviewed?

The policy is reviewed at least annually and after significant business, regulatory, or security changes.

Q6. Who approves policy exceptions?

Authorized management, together with the Information Security function, approves documented exceptions following a risk assessment.

Q7. Why are security awareness programs important?

They help personnel recognize threats, follow secure practices, and reduce organizational risk.

Q8. What information should be reported as a security incident?

Any event that may affect the confidentiality, integrity, or availability of organizational information or systems.

Q9. Why are audit logs important?

Audit logs support investigations, compliance activities, operational monitoring, and security analysis.

Q10. What is the objective of continuous improvement?

To strengthen security controls, reduce organizational risk, and improve the effectiveness of the Information Security Management System.

Revision History

Version	Date	Description
1.0	January 2024	Initial Information Security Policy
1.5	July 2025	Added Security Governance and Compliance Requirements
2.0	January 2026	Expanded Business Continuity, Logging, Policy Exceptions, Continuous Improvement, and Definitions

Related Documents

- Incident Response Process (OPS-IR-001)
- Change Management Process (OPS-CHG-001)
- Software Release Process (OPS-REL-001)
- Infrastructure Guide (TECH-INFRA-001)
- Database Backup Manual (TECH-DB-001)
- Employee Code of Conduct (HR-COC-004)